



PSI – Política de Segurança da Informação

**Documento de Diretrizes e Normas
Administrativas**

Sumário

1. INTRODUÇÃO	3
2. OBJETIVO.....	3
3. ESTRUTURA	4
3.1. Divulgação e Acesso à Estrutura Normativa	4
3.2. Aprovação e Revisão	4
4. ABRANGÊNCIA.....	5
5. PRINCÍPIOS	5
6. REQUISITOS.....	6
7. ATRIBUIÇÕES E RESPONSABILIDADES	7
7.1. Diretoria Executiva	7
7.2. Comitê Gestor de Segurança da Informação (CGSI).....	8
7.3. Gerência de Infraestrutura e Suporte	9
7.4. Administrador da Informação	10
7.5. Assessoria Jurídica.....	11
7.6. Diretorias, Gerências, Assessorias e Coordenações.....	12
7.7. Recursos Humanos	12
7.8. Empregados e Prestadores de Serviços.....	13
8. Normas Gerais.....	13
8.1. Monitoramento e Auditoria do Ambiente	13
8.2. Correio Eletrônico	14
8.3. Internet	16
8.4. Política de Senhas	18
8.5. Acesso Remoto Externo	20
8.6. Computadores, Dispositivos Portáteis e Recursos Tecnológicos	22
8.6.2 Dispositivos Portáteis	25
8.6.3 Uso da Rede	26
8.7. Datacenter.....	26
8.8. Engenharia Social	27
9. CONCLUSÃO	28

1. INTRODUÇÃO

Uma das funções desempenhadas pela Companhia de Desenvolvimento Econômico de Ribeirão Preto (CODERP) é prover o Data Center¹ para Prefeitura Municipal de Ribeirão Preto e demais clientes. Sendo assim, ela é responsável pelo armazenamento e processamento de informações de diversos segmentos como Secretaria da Educação, Secretaria da Saúde, Secretaria da Fazenda, DAERP e etc., devendo utilizar essas informações adequadamente e protegê-las contra ameaças e riscos.

Políticas, normas e procedimentos que visem garantir a segurança da informação devem ser prioridades constantes da CODERP, reduzindo-se os riscos de falhas, os danos e os prejuízos que possam comprometer a imagem e os objetivos da empresa.

A Política de Segurança da Informação (PSI) definirá as diretrizes, os limites e o direcionamento que a empresa deseja para os controles que serão implantados na proteção da informação e responsabilidade legal para todos os usuários, devendo ser cumprida e aplicada em todas as áreas da organização.

Esta PSI está baseada nas recomendações propostas pela norma técnica ABNT NBR ISO/IEC 27002:2013, reconhecida mundialmente como um código de prática para a gestão da segurança da informação, bem como está em conformidade com as leis vigentes em nosso país.

2. OBJETIVO

Definir o tratamento que deve ser dado às informações armazenadas, processadas ou transmitidas no ambiente convencional e no ambiente de tecnologia da CODERP.

Nortear a definição de normas e procedimentos específicos de segurança da informação, bem como

¹ Data Center é o local onde são concentrados os equipamentos de processamento e armazenamento de dados de uma empresa ou organização.

a implementação de controles e processos para seu atendimento.

Preservar as informações quanto à confidencialidade, integridade, disponibilidade, legalidade, autenticidade, não repúdio e auditabilidade.

3. ESTRUTURA

Política de Segurança da Informação (Política): constituída neste documento, define a estrutura, as diretrizes e as obrigações referentes à segurança da informação;

Normas de Segurança da Informação (Normas): estabelecem obrigações e procedimentos definidos de acordo com as diretrizes da Política, a serem seguidos em diversas situações em que a informação é tratada;

Procedimentos de Segurança da Informação (Procedimentos): instrumentalizam o disposto nas Normas e na Política, permitindo a direta aplicação nas atividades da CODERP.

3.1. Divulgação e Acesso à Estrutura Normativa

A Política e as Normas de Segurança da Informação devem ser divulgadas a todos os empregados e prestadores de ²serviços da CODERP e dispostas de maneira que seu conteúdo possa ser consultado a qualquer momento. Os Procedimentos de Segurança da Informação devem ser divulgados às áreas diretamente relacionadas à sua aplicação.

3.2. Aprovação e Revisão

Os documentos integrantes da estrutura normativa da Segurança da Informação da CODERP deverão ser aprovados e revisados quando motivados por algum fato relevante ou evento, e também conforme os seguintes critérios:

²Empregado ou prestador de serviços: toda e qualquer pessoa física, contratada CLT ou prestadora de serviço por intermédio de pessoa jurídica ou não, que exerça alguma atividade dentro ou fora da empresa.

- **Política**
 - Nível de Aprovação: Diretoria Executiva
 - Periodicidade de Revisão: anual
- **Normas**
 - Nível de Aprovação: - Diretoria Executiva
 - Periodicidade de Revisão: anual
- **Procedimentos**
 - Nível de Aprovação: Diretoria Executiva
 - Periodicidade de Revisão: anual

A revisão poderá ser antecipada quando motivada por algum evento ou fato relevante.

4. ABRANGÊNCIA

As diretrizes aqui estabelecidas deverão ser seguidas por todos os empregados e prestadores de serviços, que utilizem as informações da CODERP.

5. PRINCÍPIOS

Toda e qualquer informação produzida ou recebida, como resultado da atividade profissional, pelos empregados e prestadores de serviços contratados pela CODERP pertence à CODERP. As exceções devem ser explícitas e formalizadas em contrato entre as partes.

Todos os equipamentos, sistemas e informações deverão ser utilizados pelos empregados e prestadores de serviços para a realização das atividades profissionais. O uso pessoal somente é permitido caso não prejudique o desempenho de sua função, dos sistemas e dos serviços. O superior direto deverá comunicar de forma verbal, caso seja constatado algum abuso, antes do comunicado formal e providências administrativas.

Esta PSI dá ciência a cada empregado e prestador de serviços de que os ambientes, sistemas,

dispositivos informáticos³ e redes da empresa poderão ser monitorados e gravados, conforme previsto nas leis brasileiras.

6. REQUISITOS

A PSI e suas alterações, quando houver, deverão ser comunicadas a todos os empregados e prestadores de serviços da CODERP com a finalidade de que sejam cumpridas dentro e fora da empresa.

É obrigação de cada empregado e prestador de serviços manterem-se atualizados em relação a esta PSI e aos procedimentos e normas relacionadas, buscando orientação do seu superior imediato ou da Gerência de Infraestrutura e Suporte sempre que não estiver absolutamente seguro quanto à aquisição, uso ou descarte de informações.

Deverá constar em todos os contratos seja de trabalho ou de prestação de serviços, firmados entre os empregados e prestadores de serviços e a CODERP, o anexo de Termo de Confidencialidade/ Responsabilidade, como condição imprescindível para a concessão de acesso aos ativos de informação⁴ disponibilizados pela empresa.

A responsabilidade em relação à segurança da informação deve ser comunicada na fase do Edital, bem como na de contratação dos empregados e prestadores de serviços. Todos os empregados e prestadores de serviços devem ser orientados sobre os procedimentos de segurança, bem como o uso correto dos ativos, com a finalidade de reduzir possíveis riscos, devendo assinar o termo de responsabilidade.

Todo incidente que afete a segurança da informação deverá ser comunicado inicialmente à Gerência de Infraestrutura e Suporte.

Todos os requisitos de segurança da informação devem ser identificados na fase de

³Dispositivo Informático: qualquer equipamento que processa, transmite ou armazena informação (computador, HD, pen drive, impressora, modem e etc.).

⁴ Ativos de informação são informações potencialmente valiosas.

levantamento de escopo de um projeto ou sistema, e justificados, acordados, documentados, implantados e testados durante a fase de execução.

Os ambientes de produção devem ser segregados e rigidamente controlados, garantindo o isolamento necessário em relação aos ambientes de desenvolvimento, testes e homologação.

A CODERP exonera-se de toda e qualquer responsabilidade decorrente do uso indevido, negligente ou imprudente dos dados, recursos e/ou serviços concedidos aos seus empregados e prestadores de serviços, reservando-se o direito de analisar dados e evidências para obtenção de provas a serem utilizadas nos processos investigatórios de natureza civil, administrativa e criminal, bem como adotar as medidas legais cabíveis.

Esta PSI será implementada na CODERP por meio de procedimentos específicos, obrigatórios para todos os empregados e prestadores de serviços, independentemente do nível hierárquico ou função na empresa, bem como de vínculo empregatício ou prestação de serviço.

O não cumprimento dos requisitos previstos nesta PSI e demais instrumentos normativos complementares, acarretará violação às regras internas da instituição e sujeitará o usuário às medidas administrativas e legais cabíveis.

7. ATRIBUIÇÕES E RESPONSABILIDADES

7.1. Diretoria Executiva

Cabe à Diretoria Executiva:

- 7.1.1. Aprovar a Política de Segurança da Informação e suas revisões;
- 7.1.2. Aprovar e nomear os administradores da informação⁵;

⁵Administrador da informação é o responsável pela concessão, manutenção, revisão e cancelamento de autorizações de acesso a determinado conjunto de informações.

- 7.1.3. Tomar as decisões administrativas referentes aos casos de descumprimento da Política e de suas Normas.

7.2. Comitê Gestor de Segurança da Informação (CGSI)

Cabe ao CGSI:

- 7.2.1. Propor ajustes, aprimoramentos e modificações desta Política;
- 7.2.2. Propor melhorias e aprovar as Normas de Segurança da Informação;
- 7.2.3. Analisar os casos de violação desta Política e das Normas de Segurança da Informação, encaminhando à Diretoria Executiva;
- 7.2.4. Propor projetos e iniciativas relacionados à melhoria da segurança da informação da CODERP;
- 7.2.5. Propor o planejamento e a alocação de recursos financeiros, humanos e de tecnologia, no que tange à segurança da informação;
- 7.2.6. Determinar a elaboração de relatórios, levantamentos e análises que deem suporte à gestão de segurança da informação e à tomada de decisão;
- 7.2.7. Acompanhar o andamento dos principais projetos e iniciativas relacionados à segurança da informação;
- 7.2.8. Propor a relação de administradores das informações da CODERP;
- 7.2.9. Convocar, coordenar, lavrar Atas de suas reuniões e deliberações;
- 7.2.10. Prover divulgação da PSI para todos os empregados e prestadores de serviços da CODERP.

O CGSI terá no mínimo como membros:

- 7.2.11. Um (1) Representante da área de desenvolvimento;
- 7.2.12. Um (1) Representante da Infraestrutura e Suporte;

7.2.13. Um (1) Representante da Presidência;

7.2.14. Um (1) Representante da Diretoria Administrativa.

A nomeação dos membros do CGSI será definida pela Presidência com mandato de dois (2) anos, com possibilidade de uma recondução e podendo haver substituição a qualquer tempo de acordo com a deliberação da Diretoria Executiva.

A participação no CGSI é considerada de relevante interesse coletivo da companhia, e seus membros não faz jus a qualquer tipo de gratificação.

A Auditoria Interna da CODERP poderá, caso queira, indicar representante para participar das reuniões do CGSI na condição de observador ou ouvinte.

De acordo com a necessidade, e conveniência, o CGSI poderá convocar qualquer profissional da CODERP e convidados externos para participar das reuniões.

Caberá ao representante da Infraestrutura e Suporte, a coordenação dos trabalhos do CGSI, cujas atribuições abrangerão a convocação das reuniões e a realização de outros atos de suporte às atividades desenvolvidas.

As reuniões do CGSI:

7.2.15. Serão realizadas semestralmente, podendo haver convocação extraordinária sempre que necessário;

7.2.16. Serão realizadas com a presença de, no mínimo, 2/3 (dois terços) dos membros do CGSI;

7.2.17. Deverão ser registradas em Ata.

O CGSI deliberará por maioria absoluta dos votos.

7.3. Gerência de Infraestrutura e Suporte

Cabe à área de Gerência de Infraestrutura e Suporte:

7.3.1. Prover apoio às reuniões do CGSI;

- 7.3.2. Prover todas as informações de gestão de segurança da informação solicitadas pelo CGSI e pela Diretoria Executiva;
- 7.3.3. Oferecer orientação sobre a Política de Segurança da Informação e suas Normas a todos os empregados e prestadores de serviços da CODERP;
- 7.3.4. Propor projetos e iniciativas relacionados ao aperfeiçoamento da segurança da informação da CODERP, mantendo-a atualizada em relação às melhores práticas existentes no mercado e em relação às tecnologias disponíveis;
- 7.3.5. Estabelecer procedimentos e realizar a gestão dos sistemas de controle de acesso da CODERP, incluindo os processos de concessão, manutenção, revisão e suspensão de acessos aos usuários;
- 7.3.6. Analisar os riscos relacionados à segurança da informação da CODERP e apresentar relatórios sobre tais riscos ao CGSI e a Diretoria Executiva;
- 7.3.7. Realizar trabalhos de análise de vulnerabilidade, com o intuito de aferir o nível de segurança dos sistemas de informação e dos demais ambientes em que circulam as informações da CODERP;
- 7.3.8. Requisitar informações às demais áreas da CODERP (diretorias, gerências, coordenações e etc.), realizar testes e auditorias em sistemas e equipamentos, com o intuito de verificar o cumprimento da Política e das Normas de Segurança da Informação;
- 7.3.9. Estabelecer mecanismo para registro e controle de infrações à PSI e comunicar essas infrações ao CGSI e a Diretoria Executiva.

7.4. Administrador da Informação

Os administradores da informação serão empregados da CODERP, formalmente indicados pela Diretoria Executiva, responsáveis pela concessão, manutenção, revisão e cancelamento de autorizações de acesso a determinado conjunto de informações pertencentes à CODERP ou sob a sua

guarda.

Cabe ao administrador da informação:

- 7.4.1. Elaborar, para toda informação sob sua responsabilidade, matriz que relaciona cargos e funções da CODERP às autorizações de acesso concedidas;
- 7.4.2. Autorizar a liberação de acesso à informação sob sua responsabilidade, observadas a matriz de cargos e funções, a Política e as Normas de Segurança da Informação da CODERP;
- 7.4.3. Manter registro e controle atualizados de todas as liberações de acesso concedidas, determinando, sempre que necessário, a pronta suspensão ou alteração de tais liberações;
- 7.4.4. Reavaliar, sempre que necessário, as liberações de acesso concedidas, cancelando aquelas que não forem mais necessárias;
- 7.4.5. Analisar os relatórios de controle de acesso fornecidos pela área de Gerência de Infraestrutura e Suporte, com o objetivo de identificar desvios em relação à Política e às Normas de Segurança da Informação, tomando as ações corretivas necessárias;
- 7.4.6. Participar da investigação de incidentes de segurança relacionados à informação sob sua responsabilidade;
- 7.4.7. Participar, sempre que convocado, das reuniões do Comitê Gestor de Segurança da Informação (CGSI), prestando os esclarecimentos solicitados.

7.5. Assessoria Jurídica

Cabe à Assessoria Jurídica:

- 7.5.1. Manter as áreas da CODERP informadas sobre eventuais alterações legais ou regulatórias que impliquem responsabilidades ou ações envolvendo a gestão de segurança da

informação;

7.5.2. Incluir na análise e na elaboração de contratos, sempre que necessário, cláusulas específicas relacionadas à segurança da informação, com o objetivo de proteger os interesses da CODERP;

7.5.3. Avaliar, quando solicitada, as Normas e os Procedimentos de Segurança da Informação elaborados pelas diversas áreas da CODERP;

7.5.4. Tomar as providências jurídicas cabíveis em casos de incidentes de segurança.

7.6. Diretorias, Gerências, Assessorias e Coordenações

Cabe às Diretorias, Gerências, Assessorias e Coordenações:

7.6.1. Cumprir e fazer seus subordinados (empregados e prestadores de serviços) cumprirem esta Política, as Normas e os Procedimentos de Segurança da Informação;

7.6.2. Assegurar que suas equipes possuam acesso e conhecimento desta Política, das Normas e dos Procedimentos de Segurança da Informação;

7.6.3. Sugerir os Procedimentos de Segurança da Informação relacionados às suas áreas;

7.6.4. Comunicar imediatamente eventuais casos de violação de segurança da informação à área de Gerência de Infraestrutura e Suporte.

7.7. Recursos Humanos

Cabe à área de Recursos Humanos:

7.7.1. Termo de Confidencialidade/Responsabilidade, arquivando-o nos respectivos prontuários;

7.7.2. Informar prontamente à área de Gerência de Infraestrutura e Suporte, todos os desligamentos, contratações, afastamentos e alterações no quadro funcional da empresa;

7.7.3. Tomar as providências administrativas no caso de aplicação de penalidades aos trabalhadores quanto ao não cumprimento da PSI.

7.8. Empregados e Prestadores de Serviços

Entende-se por empregado e prestador de serviços toda e qualquer pessoa física ou jurídica contratada, que exerça alguma atividade dentro ou fora da empresa.

Será de inteira responsabilidade de cada empregado e prestador de serviços, todo prejuízo ou dano que vier a sofrer ou causar à CODERP ou a terceiros, em decorrência da não obediência às diretrizes e normas aqui referidas.

Cabe aos empregados e prestadores de serviços:

7.8.1. Cumprir as normas definidas na Política de Segurança;

7.8.2. Reportar, de imediato, à Gerência de Infraestrutura e Suporte, qualquer incidente de segurança ou, até mesmo, suspeitas iminentes;

7.8.3. Sugerir medidas que possam elevar os níveis de segurança das instalações na sua área de atuação.

8. Normas Gerais

8.1. Monitoramento e Auditoria do Ambiente

Para garantir as regras mencionadas nesta Política, a CODERP poderá:

8.1.1. Monitorar as estações de trabalho, servidores, correio eletrônico, conexões com a internet, dispositivos móveis ou wireless e outros componentes da rede. A informação gerada por esses sistemas poderá ser usada para identificar usuários e respectivos acessos efetuados, bem como o material manipulado;

8.1.2. Fornecer as informações obtidas pelo monitoramento e auditoria, no caso de

solicitação do gerente ou superior hierárquico;

8.1.3. Realizar, a qualquer tempo, inspeção física nos equipamentos de sua propriedade;

8.1.4. Instalar sistemas de proteção, preventivos e detectáveis, para garantir a segurança das informações e dos perímetros de acesso.

8.2. Correio Eletrônico

O uso do correio eletrônico da CODERP (@coderp) é para fins corporativos e relacionados às atividades do empregado.

É vedado o uso do correio eletrônico da CODERP para fins pessoais.

Ressaltamos ser proibido o uso do correio eletrônico para:

8.2.1. Enviar sem autorização mensagens não solicitadas para múltiplos destinatários, exceto se relacionadas a uso legítimo da empresa;

8.2.2. Enviar sem autorização mensagens pelo endereço de seu departamento ou usando o nome ou endereço de correio eletrônico de outra pessoa;

8.2.3. Enviar qualquer mensagem por meios eletrônicos que torne seu remetente, a CODERP ou suas unidades vulneráveis a ações cíveis ou criminais;

8.2.4. Divulgar sem autorização qualquer informação ou imagem de tela de sistemas, documentos e afins;

8.2.5. Falsificar informações de endereçamento, adulterar cabeçalhos para esconder a identidade de remetentes ou destinatários, com o objetivo de evitar as punições previstas;

8.2.6. Produzir, transmitir ou divulgar mensagem ou imagem que:

8.2.6.1. Contenha qualquer ato ou forneça orientação que conflite ou contrarie os interesses da CODERP;

- 8.2.6.2. Contenha ameaças eletrônicas, como: spam⁶, mail bombing⁷, vírus de computador e etc.;
- 8.2.6.3. Contenha arquivo executável (.exe, .com, .bat, .pif, .js, .vbs, .hta, .src, .cpl, .reg, .dll, .inf) ou qualquer outra extensão que represente um risco à segurança;
- 8.2.6.4. Vise obter acesso não autorizado a outro computador, servidor ou rede;
- 8.2.6.5. Vise interromper um serviço, servidores ou rede de computadores por meio de qualquer método ilícito ou não autorizado;
- 8.2.6.6. Vise burlar qualquer sistema de segurança;
- 8.2.6.7. Vise vigiar secretamente ou assediar outro usuário;
- 8.2.6.8. Vise acessar informações confidenciais sem explícita autorização do proprietário;
- 8.2.6.9. Vise acessar indevidamente informações que possam causar prejuízos a qualquer pessoa;
- 8.2.6.10. Inclua imagens criptografadas ou de qualquer forma mascaradas;
- 8.2.6.11. Contenha anexo (s) superior (es) a 15 MB para envio e recebimento ou tenha conteúdo considerado impróprio, obsceno ou ilegal;
- 8.2.6.12. Seja de caráter calunioso, difamatório, degradante, infame, ofensivo, violento, ameaçador, pornográfico, entre outros;
- 8.2.6.13. Contenha perseguição preconceituosa baseada em sexo, raça,

⁶ O termo spam significa uma mensagem eletrônica não-solicitada geralmente enviada em massa.

⁷ O mail bombing consiste em enviar milhares de mensagens para uma caixa de correio eletrônico para sobrecarregar um servidor ou uma conta de e-mail.

incapacidade física ou mental ou outras situações protegidas;

8.2.6.14. Tenha fins políticos partidários locais ou do país (propaganda política);

8.2.6.15. Inclua material protegido por direitos autorais sem a permissão do detentor dos direitos.

As mensagens de correio eletrônico sempre deverão incluir assinatura com o seguinte formato:

8.2.7. Nome do empregado;

8.2.8. Gerência ou departamento;

8.2.9. Nome da empresa;

8.2.10. Telefone(s);

8.2.11. Correio eletrônico.

8.3. Internet

Todas as regras atuais da CODERP visam o desenvolvimento de um comportamento ético e profissional do uso da internet. Embora a conexão direta e permanente da rede corporativa da empresa com a internet ofereça um grande potencial de benefícios, ela abre a porta com riscos significativos para os ativos de informação.

Qualquer informação acessada, transmitida, recebida ou produzida na internet está sujeita a auditoria. Portanto, a CODERP, em total conformidade legal, reserva-se o direito de monitorar e registrar todos os acessos a ela.

Os equipamentos, tecnologia e serviços fornecidos para o acesso à internet são de propriedade da empresa, que pode analisar e, se necessário, bloquear qualquer arquivo, site, correio eletrônico, domínio ou aplicação armazenados na rede ou internet, estejam eles em disco local, na estação ou em áreas privadas da rede, visando assegurar o cumprimento de sua PSI.

A CODERP, ao monitorar a rede interna, pretende garantir a integridade dos dados e programas. Toda tentativa de alteração dos parâmetros de segurança, por qualquer empregado e ou prestador de serviços, sem o devido credenciamento e a autorização para tal, será julgada inadequada e os riscos relacionados serão informados ao empregado e ou prestador de serviços e, ao superior imediato. O uso de qualquer recurso para atividades ilícitas poderá acarretar sanções de ações administrativas, cíveis e criminais, bem como, nesses casos, a instituição cooperará ativamente com as autoridades competentes.

Somente os empregados e prestadores de serviços que estão devidamente autorizados a falar em nome da CODERP para os meios de comunicação, poderão manifestar-se, em seu nome, em qualquer meio ou veículo de comunicação, seja por documento físico ou digital.

Apenas os empregados e prestadores de serviços autorizados pela instituição poderão copiar, captar, imprimir ou enviar imagens da tela para terceiros, devendo atender à norma interna de uso de imagens, à Lei de Direitos Autorais, à proteção da imagem garantida pela Constituição Federal e demais dispositivos legais.

É proibida a divulgação ou o compartilhamento indevido de informações da área administrativa em listas de discussão, sites ou comunidades de relacionamento, salas de bate-papo, comunicadores instantâneos ou qualquer outra tecnologia correlata que venha surgir na internet.

Os empregados e prestadores de serviços com acesso à internet poderão efetuar o download somente de programas ligados diretamente às suas atividades na CODERP e deverão providenciar o que for necessário para regularizar a licença e o registro desses programas, desde que autorizados pela Gerência de Infraestrutura e Suporte.

O uso, a instalação, a cópia ou a distribuição não autorizada de softwares que tenham direitos autorais, marca registrada ou patente na internet são expressamente proibidos. Qualquer software não autorizado baixado será excluído pela Gerência de Infraestrutura e Suporte. Situações ocorridas anteriores à publicação dessa Política serão tratadas pela Diretoria Executiva da CODERP.

Os empregados e prestadores de serviços não poderão em hipótese alguma utilizar os recursos da CODERP para efetuar o download ou distribuição de software ou dados pirateados, atividade

considerada delituosa de acordo com a legislação nacional.

O download e a utilização de programas de entretenimento, jogos ou músicas (em qualquer formato) poderão ser realizados por usuários que tenham atividades profissionais relacionadas a essas categorias, mediante solicitação e aprovação da área técnica responsável, em regime de exceção.

Empregados e prestadores de serviços com acesso à internet não poderão efetuar upload de qualquer software licenciado à CODERP ou de dados de sua propriedade aos seus parceiros e clientes, sem expressa autorização do responsável pelo software ou pelos dados. Os empregados e prestadores de serviços não poderão utilizar os recursos da CODERP para deliberadamente propagar qualquer tipo de vírus, worm⁸, cavalo de troia, spam, assédio, constrangimento ou programas para controle de outros computadores.

O acesso a softwares peer-to-peer⁹ (BitTorrent e afins) não serão permitidos. Já os serviços de streaming¹⁰ (rádios on-line, canais de broadcast e afins), comunicação instantânea (Gtalk, Skype e afins) e redes sociais (Whatsap, Facebook, LinkedIn e afins) poderão ser permitidos em regime de exceção quando formalmente autorizado pela Gerência de Infraestrutura e Suporte.

Não é permitido o acesso à internet por meio de proxy¹¹ não autorizado pela CODERP.

8.4. Política de Senhas

Os dispositivos de identificação com senhas protegem a identidade do empregado e prestador de serviços usuário, evitando e prevenindo que uma pessoa se faça passar por outra perante a CODERP

⁸ Worm é um programa autorreplicante, diferente de um vírus

⁹ Peer-to-peer ou P2P consiste num conjunto de computadores que comunicam entre si de forma descentralizada. isto é, São nós centrais responsáveis por gerir as ligações entre eles sem a necessidade de um centralizador (servidor). É muito utilizado para compartilhamento de arquivos.

¹⁰ Streaming é frequentemente utilizado para distribuir conteúdo multimídia por meio da Internet.

¹¹ Proxy é um servidor intermediário, nesse caso tornando possível o acesso à internet a partir de uma máquina externa.

ou a terceiros.

O uso de senhas de identificação de outra pessoa constitui crime tipificado no Código Penal Brasileiro (art. 307 - Falsidade Ideológica).

Tal norma visa estabelecer critérios de responsabilidade sobre o uso dos dispositivos de identificação e deverá ser aplicada a todos os empregados e prestadores de serviços.

Todo e qualquer sistema de identificação pessoal, em hipótese alguma, poderá ser compartilhado com outras pessoas.

O Departamento de Recursos Humanos da CODERP é o responsável pela emissão e pelo controle dos documentos físicos de identidade dos empregados e prestadores de serviços. A Gerência de Infraestrutura e Suporte e os administradores da informação respondem pela criação da identidade lógica dos empregados e prestadores de serviços na instituição.

Devem ser distintamente identificados os visitantes, estagiários, empregados temporários, empregados regulares e prestadores de serviços, sejam eles pessoas físicas ou jurídicas. Ao realizar o primeiro acesso ao ambiente de rede local, o usuário deverá trocar imediatamente a sua senha, conforme as orientações apresentadas.

Os usuários que não possuem perfil de administrador deverão ter senha de tamanho variável, possuindo no mínimo 6(seis) caracteres alfanuméricos, utilizando caracteres especiais (# \$ %) e variação entre caixa-alta e caixa-baixa (maiúsculo e minúsculo) sempre que possível.

Já os usuários que possuem perfil de administrador ou acesso privilegiado deverão utilizar uma senha de no mínimo 10 (dez) caracteres, alfanumérica, utilizando caracteres especiais (# \$ %) e variação de caixa-alta e caixa-baixa (maiúsculo e minúsculo) desde que não tenha restrição no aplicativo.

É de responsabilidade de cada usuário a memorização de sua própria senha, bem como a proteção e a guarda dos dispositivos de identificação que lhe forem designados.

As senhas não devem ser anotadas ou armazenadas em arquivos eletrônicos (Word, Excel, etc.), compreensíveis por linguagem humana (não criptografados); não devem se basear em informações pessoais, como próprio nome, nome de familiares, data de nascimento, endereço, placa de veículo, nome da empresa, nome do departamento; e não devem ser constituídas de combinações óbvias de

teclado, como "abcdefgh", "87654321", "q1w2e3" entre outras.

Após 3(três) tentativas de acesso sem sucesso, a conta do usuário será bloqueada, caso o ambiente acessado permita esse procedimento. Para o desbloqueio é necessário que o usuário entre em contato com a Gerência de Infraestrutura e Suporte da CODERP. Em alguns casos o bloqueio poderá ser temporário (por exemplo 10 minutos) e, após esse tempo, o usuário é desbloqueado automaticamente.

Deverá ser estabelecido um procedimento para a renovação de senha (confirmar a identidade).

Os usuários devem alterar sua senha em caso de suspeita de que terceiros tenham obtido acesso à sua conta.

A periodicidade máxima para troca das senhas é 365 (trezentos e sessenta e cinco) dias, caso o ambiente acessado permita esse procedimento. Os sistemas críticos e sensíveis para a instituição e os usuários com privilégios administrativos devem exigir a troca de senhas a cada 180 (cento e oitenta) dias. Os sistemas devem forçar a troca das senhas dentro desse prazo máximo.

Todos os acessos devem ser imediatamente bloqueados quando se tornarem desnecessários. Em caso de demissão, o Departamento de Recursos Humanos deverá imediatamente comunicar tal fato à Gerência de Infraestrutura e Suporte, permitindo que essa providência seja tomada. A mesma conduta se aplica aos usuários cujo contrato ou prestação de serviços tenha se encerrado, bem como aos usuários de testes e outras situações similares.

Caso o empregado ou prestador de serviços esqueça sua senha, ele deverá requisitar formalmente a troca por meio de chamado técnico.

8.5. Acesso Remoto Externo

Objetivo: estabelecer critérios para a disponibilização do serviço de acesso remoto externo à rede corporativa da CODERP, bem como as regras para a sua utilização, visando à prevenção do acesso não autorizado às informações.

Diretrizes Gerais:

- a) O acesso remoto aos serviços corporativos somente deve ser disponibilizado aos empregados ou prestadores de serviços que, oficialmente, executem atividade vinculada à atuação institucional da CODERP e que necessitam deste serviço para execução de suas atividades institucionais, desde que autorizados;
- b) Os empregados ou prestadores de serviços da CODERP, para o desempenho de suas atribuições, poderão ter permissão de acesso remoto aos recursos computacionais da rede corporativa da CODERP, quando necessário, mediante autorização prévia;
- c) A liberação de acesso remoto, só será efetivada após avaliação da Gerência de Infraestrutura e Suporte e submetida à aprovação da Diretoria Executiva, para que se evitem ameaças à integridade e sigilo das informações contidas na rede corporativa da CODERP. Será feita uma análise criteriosa, podendo ser negado o acesso remoto caso comprometa a segurança do ambiente;
- d) A solicitação do acesso remoto deve conter, no mínimo, as seguintes informações:
- Data da solicitação;
 - Tipo de solicitação;
 - Tempo de validade do acesso remoto;
 - Justificativa;
 - Dados do solicitante;
 - Dados do usuário.
- e) A disponibilização de acesso remoto à rede corporativa da CODERP para outras organizações deve obedecer às seguintes regras:
- Direitos de acesso definidos por contrato formal entre as partes;
 - Acesso temporário e limitado às necessidades de negócio;
 - Revisão periódica dos direitos de acesso;
 - Utilização de solução que permita a implementação e controle de regras de acesso.
- f) O serviço de acesso remoto deverá ser cancelado sob as seguintes condições:
- Finalização do período especificado na solicitação ou contrato;

- Perda da necessidade de utilização do serviço;
- Transferência do usuário para outro setor ou departamento;
- Identificação de vulnerabilidade, risco ou uso indevido no acesso concedido.

g) As conexões remotas à rede corporativa da CODERP devem ocorrer da seguinte maneira:

- Utilização de autenticação;
- As senhas e as informações que trafegam entre a estação remota e a rede corporativa da CODERP devem estar criptografadas;
- E todas as conexões e acessos serão registrados em log, para posterior auditoria da CODERP, se necessário;

h) Cada usuário deve manter suas credenciais de acesso (login e senha) em sigilo absoluto e não fornecê-lo a outra pessoa, garantindo assim, a impossibilidade de acesso indevido por pessoas não autorizadas;

i) É vedada a utilização do acesso remoto para fins não relacionados às atividades do empregado na companhia.

8.6. Computadores, Dispositivos Portáteis e Recursos Tecnológicos

A CODERP é proprietária dos equipamentos fornecidos, cabendo a cada um utilizá-los e manuseá-los corretamente para as atividades de interesse da empresa, bem como cumprir as recomendações constantes nos procedimentos operacionais fornecidos pelas gerências responsáveis.

A CODERP reserva-se o direito de inspecionar qualquer equipamento a qualquer momento.

É proibido qualquer procedimento de manutenção física ou lógica, instalação, desinstalação, configuração ou modificação, sem o conhecimento prévio e o acompanhamento de um técnico da Gerência de Infraestrutura e Suporte da CODERP, ou de quem este determinar. As gerências que necessitarem fazer testes deverão solicitá-los previamente à Gerência de Infraestrutura e Suporte, ficando responsáveis jurídica e tecnicamente pelas ações realizadas.

Todas as atualizações e correções de segurança do sistema operacional ou aplicativos deverão ser realizadas constantemente, entretanto somente após a sua disponibilização oficial pelo fabricante ou fornecedor.

Os computadores e dispositivos portáteis¹² deverão ter versões do software antivírus instalados e ativados permanentemente, mantendo-os atualizados. O usuário, em caso de suspeita de vírus ou problemas na funcionalidade, deverá acionar o departamento técnico responsável mediante registro de chamado no setor de Network Operation Center (NOC) (Centro de Operação de Rede).

A transferência ou a divulgação de qualquer informação, software, programa ou instruções de computador para terceiros, por qualquer meio (físico ou lógico), somente poderá ser realizada com a identificação positiva do solicitante junto à Gerência responsável por esta informação, e estando de acordo com a classificação¹³ dessa informação e a pertinente necessidade do destinatário.

Ao transportar computador ou dispositivo portátil em veículos motorizados, o mesmo deverá ser colocado sempre no interior do porta-malas, onde não ficará visível, não o deixando no interior do veículo quando ele estiver estacionado.

8.6.1 Uso dos Equipamentos

No uso dos computadores, dispositivos móveis, equipamentos e recursos de informática, algumas regras devem ser atendidas:

- Todos os computadores de uso individual deverão ter o BIOS¹⁴ protegido através de senha, com o objetivo de restringir o acesso de pessoas não autorizadas. Tais senhas serão definidas pela Gerência de Infraestrutura e Suporte da CODERP, que terá acesso a elas para manutenção dos equipamentos;
- Os empregados ou prestadores de serviços devem informar ao departamento técnico qualquer identificação de dispositivo estranho conectado ao seu computador;
- É vedada a abertura ou o manuseio de computadores ou outros equipamentos de informática

¹² Dispositivo portátil ou móvel é qualquer equipamento eletrônico com atribuições de mobilidade de propriedade da instituição, ou pessoal aprovado e permitido por sua Gerência de Infraestrutura e Suporte, como: notebooks, tablets, smartphones, harddisk externo e pendrives

¹³ Classificação da Informação: é uma maneira de determinar como esta informação vai ser tratada e protegida durante todo o seu ciclo de vida.

¹⁴ O BIOS é um programa de computador pré-gravado em memória permanente (firmware) executado por um computador quando ligado. Ele é responsável pelo suporte básico de acesso ao hardware, bem como por iniciar a carga do sistema operacional.

para qualquer tipo de reparo que não seja realizado por um técnico da Gerência de Infraestrutura e Suporte da CODERP ou por terceiros devidamente contratados para o serviço;

- O consumo de alimentos e bebidas deverão ser realizados em ambientes apropriados da empresa (copa – *lanches rápidos* e refeitório - *refeições*). A hidratação com água é permitida, respeitando-se os cuidados necessários com os equipamentos.
- O empregado ou prestador de serviços deverá manter a configuração do equipamento disponibilizado pela CODERP, seguindo os devidos controles de segurança exigidos pela PSI e pelas normas específicas da instituição, assumindo a responsabilidade das informações;
- Todos os dispositivos e terminais de computador deverão estar bloqueados (protegidos por senha), quando não estiverem sendo acessados por seu usuário;
- Todos os recursos tecnológicos adquiridos pela CODERP devem ter imediatamente suas senhas padrão alteradas;

É proibido o uso de computadores e recursos tecnológicos da CODERP para:

- Tentar ou obter acesso não autorizado a outro computador, servidor ou rede;
- Burlar quaisquer sistemas de segurança;
- Acessar informações confidenciais sem explícita autorização do proprietário;
- Vigiar secretamente outrem por dispositivos eletrônicos ou softwares, como, por exemplo, analisadores de pacotes (sniffers);
- Interromper um serviço, servidores ou rede de computadores por meio de qualquer método ilícito ou não autorizado;
- Usar qualquer tipo de recurso tecnológico para cometer ou ser cúmplice de atos de violação, assédio, constrangimento, manipulação ou supressão de direitos autorais ou propriedades intelectuais sem a devida autorização legal do titular;
- Hospedar qualquer material que viole a legislação vigente no país, a moral, os bons costumes e a ordem pública;

É proibido o uso de software não licenciado ou não autorizado.

Situações ocorridas anteriormente à publicação dessa Política de Segurança serão tratadas pela Diretoria Executiva da CODERP.

8.6.2 Dispositivos Portáteis

Todo empregado ou prestador de serviços deverá realizar periodicamente cópia de segurança (backup) dos dados do dispositivo móvel pertencente à CODERP sob sua guarda. Deverá, também, manter esses backups em local diferente de sua fonte de origem.

É permitido o uso de rede banda larga de locais conhecidos pelo empregado ou prestador de serviços como: sua casa, hotéis, fornecedores e clientes.

Os dispositivos móveis que permanecerem em qualquer área física da CODERP, deverão estar trancados em local de acesso restrito e seguro, quando não estiverem sendo utilizados pelo usuário.

Ao viajar com um computador tipo portátil, o usuário deve:

- manter o computador tipo portátil sempre consigo;
- ao utilizar um taxi ou outro meio de deslocamento, necessário a verificação que retirou toda a sua bagagem, inclusive o computador, quando chegar em seu destino final.

O transporte do computador tipo portátil nas ruas é bastante observado pelos criminosos, portanto, é aconselhável discrição e atenção ao ambiente e seus arredores no trajeto até o seu destino.

Em caso de perda de acessório (exemplo: mala, capa, mouse e etc.) o colaborador será responsável pelo seu ressarcimento.

É responsabilidade do empregado ou prestador de serviços, no caso de furto ou roubo de um dispositivo móvel fornecido pela CODERP, notificar imediatamente seu gestor direto e a Gerência de Infraestrutura e Suporte. Também deverá procurar a ajuda das autoridades policiais registrando, assim que possível, um boletim de ocorrência (BO).

O empregado ou prestador de serviços deverá estar ciente de que o uso indevido do dispositivo móvel não é permitido, sendo o único responsável por quaisquer danos, diretos ou indiretos, presentes ou futuros, que venham causar à CODERP ou à terceiros.

8.6.3 Uso da Rede

Arquivos pessoais ou não pertinentes ao negócio da CODERP (fotos, músicas, vídeos, etc.) não deverão ser copiados ou movidos para a rede, pois podem sobrecarregar o armazenamento nos servidores. Caso identificada a existência desses arquivos, eles deverão ser excluídos definitivamente sem aviso prévio.

Diretórios ou pastas de acesso público, não deverão ser utilizados para armazenamento de arquivos que contenham assuntos sigilosos ou de natureza específica. Devem ser utilizados apenas para armazenar informações de interesses gerais.

Documentos imprescindíveis para as atividades dos empregados ou prestadores de serviços na CODERP deverão ser salvos na rede. Tais arquivos, se gravados apenas localmente nos computadores (por exemplo, no drive C:), não terão garantia de cópias de segurança (backup) e poderão ser perdidos caso ocorra uma falha no computador, sendo, portanto, de responsabilidade do próprio usuário.

Os empregados ou prestadores de serviços da CODERP e detentores de contas privilegiadas não devem executar nenhum tipo de comando ou programa que possa sobrecarregar os serviços existentes na rede corporativa sem a prévia solicitação e a autorização da Gerência de Infraestrutura e Suporte.

8.7. Datacenter

O acesso ao Datacenter somente deverá ser feito por sistema de autenticação. Por exemplo: biometria, cartão magnético entre outros.

Todo acesso ao Datacenter, pelo sistema de autenticação, deverá ser registrado (usuário, data e hora) mediante software próprio.

O acesso ao Datacenter, por meio de chave, apenas poderá ocorrer em situações de emergência, quando a segurança física do Datacenter estiver comprometida, como incêndio, inundação, abalo da estrutura predial ou quando o sistema de autenticação não estiver funcionando.

Deverão existir duas cópias de chaves da porta do Datacenter. Uma das cópias deverá ficar de posse do coordenador responsável pelo Datacenter, e a outra, de posse da diretoria.

O Datacenter deverá ser mantido limpo e organizado. Qualquer procedimento de limpeza no ambiente deverá ser acompanhado pelo Departamento de Infraestrutura.

Não é permitida a entrada de nenhum tipo de alimento, bebida, produto fumígeno ou inflamável no Datacenter.

A entrada ou retirada de quaisquer equipamentos do Datacenter somente se dará com o preenchimento da solicitação de liberação pelo empregado ou prestador de serviços solicitante e a autorização formal desse instrumento pelo responsável do Datacenter.

No caso de desligamento, transferência de setor ou departamento de empregados ou prestadores de serviços que possuam acesso ao Datacenter, imediatamente deverá ser providenciada a sua exclusão do sistema de autenticação e da lista de colaboradores autorizados.

8.8. Engenharia Social

A engenharia social é qualquer método usado para enganar ou explorar a confiança das pessoas para a obtenção de informações sigilosas e importantes, tanto da empresa como do empregado ou prestador de serviços em questão. Para isso, alguém pode se passar por outra pessoa, assumir outra personalidade, fingir que é um profissional de determinada área e etc..

Para evitar esse método, todos os empregados ou prestadores de serviços devem estar cientes das seguintes regras:

- Nenhum empregado ou prestador de serviços da empresa está autorizado a passar informação às pessoas ou agentes estranhos à empresa;
- O suporte técnico em hipótese alguma entrará em contato com usuário caso o mesmo não solicite suporte técnico ou auxílio em determinadas funções no sistema e na rede interna;

- O suporte técnico em hipótese alguma encaminhará por e-mail, solicitações de senhas ou qualquer outra informação do usuário do sistema ou empregado ou prestador de serviços que opera o mesmo;
- Caso sejam necessárias informações de usuários do sistema, empregados ou prestadores de serviços, a solicitação deverá ser encaminhada ao departamento de Recursos Humanos da empresa, antes de ser feita qualquer ação na rede interna;
- Toda a solicitação de suporte técnico deverá ser feito pelo usuário do sistema ou equipamento, ou pelo seu superior imediato ao setor de NOC que deverá gerar e informar o número da Ordem de Serviço (OS). Para a realização do suporte, o técnico deverá confirmar o número da OS com o usuário solicitante;
- Caso alguém entre em contato por telefone, e-mail, softwares de comunicações, solicitando informações sigilosas da empresa ou do usuário, o empregado ou prestador de serviços abordado deverá entrar em contato com o responsável pela rede interna, ou diretamente com a Gerência de Infraestrutura e Suporte, informando tais ações.

9. CONCLUSÃO

Assim como a ética, a segurança deve ser entendida como parte fundamental da cultura da CODERP. Ou seja, qualquer incidente de segurança, entender-se-á como alguém agindo contra a ética e os bons costumes exigidos pela empresa.

O não cumprimento desta PSI e demais instrumentos normativos que complementam o processo de segurança, constitui falta grave e o empregado ou prestador de serviços está sujeito a penalidades administrativas, cíveis e criminais.

Ribeirão Preto/SP 27 de agosto de 2020.

Aurílio Sérgio Costa Caiado
Diretor Presidente

Renato Gomes
Diretor Fin/Adm

Renato Cesar Ramos
Diretor T.I.